

ENTERPRISE CYBERSECURITY RISK ASSESSMENT

IslandLink Business Services Ltd. (Fictional)

Cybersecurity | GRC | Enterprise Risk Management | NIST CSF 2.0

Prepared by Chisomo Dunkley

Assessment date: 26 August 2026

Portfolio Case Study - Simulated Environment

Purpose and Disclaimer

This report is a simulated professional cybersecurity risk assessment for a fictional Jamaican mid-sized company. No real company, employee, customer, system or confidential data is represented. Findings, scores, owners, dates and recommendations are illustrative. NIST and ISO references support methodology and control mapping only; this report is not a certification, regulatory determination or legal opinion.

Document Control and Report Structure

Document Control

Field	Value
Document	Enterprise Cybersecurity Risk Assessment Report
Organization	IslandLink Business Services Ltd. (Fictional)
Assessment date	26 August 2026
Assessment type	Enterprise cybersecurity risk assessment - portfolio simulation
Primary framework	NIST Cybersecurity Framework (CSF) 2.0
Supporting references	NIST SP 800-30 Rev. 1; NIST SP 1308; ISO/IEC 27001:2022
Assessment status	Complete - priority remediation required
Distribution	Portfolio / recruiter review

Report Structure

1. Executive Summary and Management Assessment
2. Organization, Scope and Methodology
3. Technology Environment and Crown-Jewel Assets
4. Threat and Vulnerability Assessment
5. Enterprise Risk Profile and Heatmaps
6. Top Enterprise Risks
7. NIST CSF 2.0 Current vs. Target Profile
8. Risk Treatment Strategy and 30/60/90-Day Roadmap
9. Governance, Metrics and Assurance
10. Management Recommendations and Conclusion
11. Appendices: Asset Inventory, Risk Register, CSF Profile and References

Project Artifact Set

Artifact	Purpose
01 - Enterprise Cybersecurity Asset Inventory	Business context, 35 assets, 10 services, 8 crown jewels, criticality and recovery requirements.
02 - Threat & Vulnerability Matrix	36 realistic threat/failure scenarios, weaknesses, attack vectors and attack paths.
03 - Cybersecurity Risk Register	22 enterprise risks with inherent/projected residual scoring, ownership and treatment decisions.
04 - Risk Heatmap & Executive Dashboard	Management views of risk distribution, movement, appetite, ownership and remediation.
05 - NIST CSF 2.0 Control Mapping	Current vs. Target Profile across all 22 CSF Categories, evidence gaps and actions.
06 - Risk Treatment Plan	18 time-bound remediation actions, dependencies, milestones, success metrics and roadmap.

1. Executive Summary

35

Assets Assessed

36

Threat Scenarios

22

Enterprise Risks

19

Critical Inherent Risks

6

Projected High Residual

46%

CSF Current Alignment

18

Treatment Actions

252 days

Planned Effort

IslandLink Business Services Ltd. is modeled as a Jamaican mid-sized business with approximately 150 employees, a head office in Kingston, a branch office in Montego Bay and a hybrid workforce. The organization depends heavily on Microsoft 365 and Entra ID, cloud accounting/CRM/HR systems, employee laptops, firewalls/VPN, legacy Windows infrastructure, backups, internet connectivity and third-party service providers.

The assessment identified a concentrated set of enterprise risks driven by incomplete strong authentication, privileged-access concentration, legacy infrastructure, ransomware/recovery weaknesses, business email compromise, perimeter exposure, fragmented security monitoring, cloud data-sharing controls and trusted third-party access. Nineteen of the 22 enterprise risks are rated Critical on an inherent basis, reflecting the intentionally imperfect simulated environment and the severe business consequences associated with crown-jewel compromise.

The modeled target-state profile assumes the proposed treatment controls are fully implemented and supported by operating evidence. Under that assumption, no risks remain Critical: six are projected High and sixteen Moderate. These projected residual ratings must not be treated as current residual risk until the evidence and success criteria in the treatment plan demonstrate that controls are operating effectively.

Management Assessment

Current posture: Elevated and above the fictional organization's stated risk appetite. Management should continue normal operations only with an actively governed remediation program, immediate treatment of credential/privilege/perimeter/recovery risks, and explicit acceptance of any material risk that remains above appetite after target dates. Target posture: materially improved and manageable, subject to evidence-based validation.

Enterprise Risk Distribution

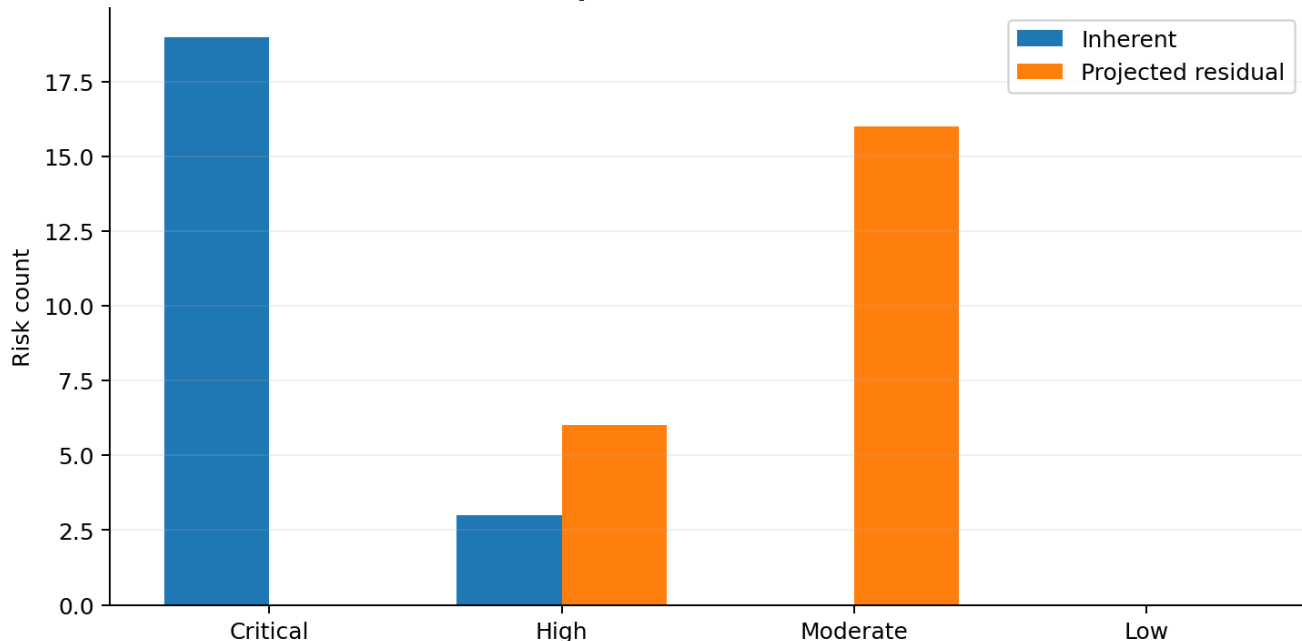


Figure 1. Inherent vs. projected residual enterprise risk distribution.

2. Management Decision and Immediate Priorities

Decision

The recommended management decision is: **PRIORITY REMEDIATION REQUIRED**, with controlled continuation of business operations. The assessment does not identify a reason to suspend ordinary operations; however, the concentration of Critical inherent risk means the remediation program should be treated as an enterprise priority rather than discretionary IT improvement.

First 60-Day Priorities

Priority	Action	Risk(s)	Owner	Target
1	Enforce universal MFA and remove cloud/VPN authentication exemptions.	R-03; R-13	IT Manager	15 Sep 2026
2	Implement independent payment/vendor-bank verification and anti-impersonation controls.	R-01; R-12	Finance Manager	30 Sep 2026
3	Harden firewalls/VPN: supported firmware, MFA, rule review and centralized logs.	R-13; R-05	IT Manager	15 Oct 2026
4	Enable immutable/isolated backup protection and complete a timed restoration test.	R-05; R-06	IT Manager	31 Oct 2026
5	Implement privileged-access governance and hardened administrator access.	R-04; R-20	IT Manager	31 Oct 2026
6	Approve cyber risk appetite and quarterly management risk-review process.	R-01 to R-22	Executive Team	31 Oct 2026

Risk Acceptance Rule

Critical or High risks should not be considered accepted by default. If remediation cannot be completed by the target date, the accountable owner should document the reason, interim safeguards, updated completion date and explicit management acceptance. Risk acceptance should be time-bound and reviewed at the next quarterly cyber-risk meeting.

Why These Priorities Come First

- Identity and remote-access weaknesses create direct initial-access paths into cloud services and internal networks.
- Finance controls can prevent high-impact fraud with relatively low implementation cost.
- Perimeter and VPN weaknesses combine public exposure with privileged network access.
- Backups are the final recovery control for ransomware and destructive incidents; they must be proven through restoration testing.
- Privileged credentials and administrator workstations can turn a single compromise into enterprise-wide control loss.
- Formal risk appetite and oversight ensure unresolved exposure is consciously owned rather than silently inherited.

3. Organization and Business Context

Fictional Organization Profile

Attribute	Scenario
Organization	IslandLink Business Services Ltd. (Fictional)
Industry	Business services and distribution support
Jurisdiction	Jamaica
Locations	Kingston head office; Montego Bay branch
Employees	Approximately 150
Work model	Hybrid - office, field and remote users
Primary cloud platform	Microsoft 365 / Entra ID
Core technology	Windows endpoints, SaaS applications, cloud storage, firewalls/VPN, legacy Windows servers
Risk-management maturity	Developing - operational controls exist, but governance, evidence and consistency are incomplete

The company has grown through incremental technology adoption. Security controls exist, but governance is inconsistent: asset ownership is not always formally maintained, privileged administration is concentrated in a small IT team, selected legacy services remain in use, several critical services are vendor-managed, and centralized monitoring is incomplete.

Business Objectives Protected by Cybersecurity

- Maintain reliable email, collaboration and remote-work capability.
- Protect the integrity and availability of financial operations and payment processes.
- Protect customer, employee and financial information from unauthorized access or disclosure.
- Maintain resilient customer service, sales, HR and operational support processes.
- Preserve trusted recovery capability during ransomware, outage or infrastructure failure.
- Maintain customer and supplier trust in company communications, domains and public web services.

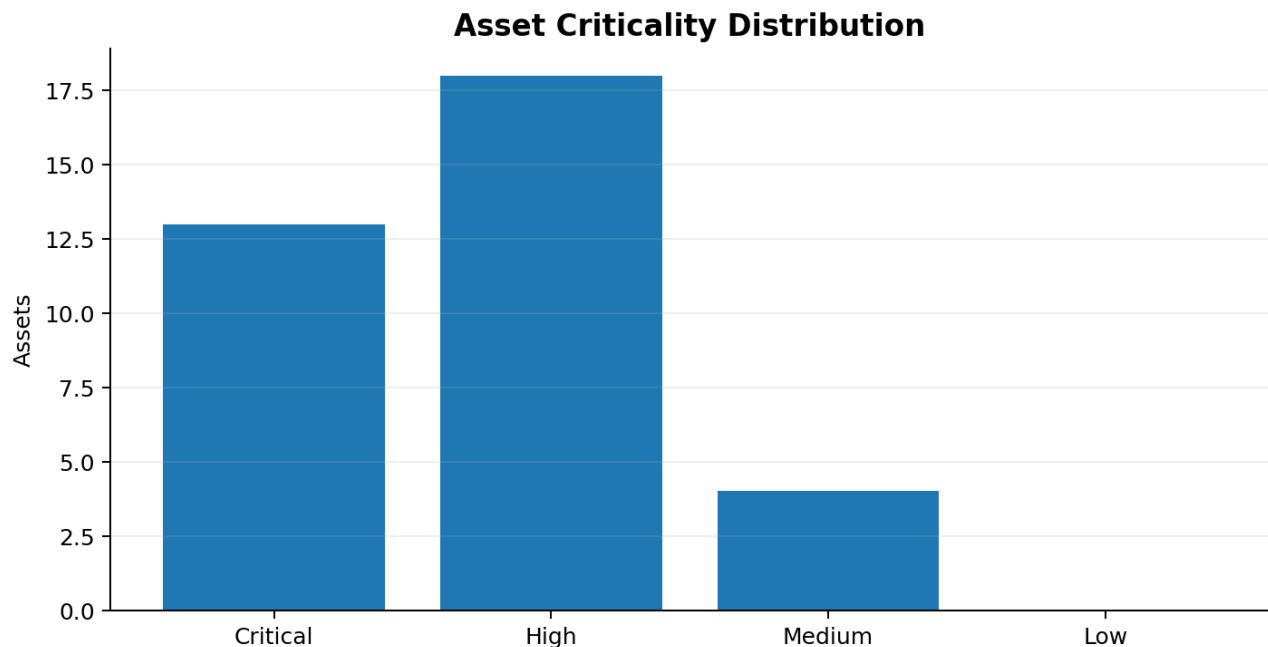


Figure 2. Asset criticality distribution for the 35-item inventory.

4. Scope, Assumptions and Assessment Methodology

Assessment Scope

In Scope	Examples
Identity and productivity cloud	Microsoft 365, Entra ID, executive/finance mailboxes, SharePoint/OneDrive
Business SaaS	Accounting, CRM and HR information systems
Endpoints and administration	Employee, executive, finance and IT administrator workstations
Networks and remote access	Kingston/Montego Bay firewalls, switches, Wi-Fi, VPN and ISPs
Legacy infrastructure	Active Directory, file server and virtualization host
Security and recovery	EDR, email security, password manager, logging repository and backups
External dependencies	RMM/MSP, SaaS suppliers, website/DNS registrar and telecom providers
Information assets	Customer, employee, financial and privileged-credential datasets

Out of Scope

- Client-owned systems except where IslandLink exchanges data or depends on an interface.
- Industrial/operational technology, which is not operated in the fictional environment.
- Personal home networks beyond corporate device and remote-access controls.
- A formal legal compliance audit or ISO certification assessment.
- Live penetration testing or vulnerability scanning against any real system.

Assessment Workflow

12. Establish business context, business services, asset inventory, owners, data classes and recovery requirements.
13. Identify threat sources, attack vectors, weaknesses and realistic multi-stage attack paths.
14. Consolidate technical scenarios into enterprise-level risk statements with accountable owners.
15. Score inherent likelihood and impact using a 5 x 5 matrix and document treatment decisions.
16. Model projected residual risk after planned controls are operating effectively.
17. Create NIST CSF 2.0 Current and Target Profiles across all 22 Categories.
18. Build a time-bound remediation plan with evidence requirements and measurable success criteria.

Important Scoring Note

The projected residual score is a target-state model, not a statement that the control already works. Residual risk should only be re-baselined after evidence demonstrates effective control operation.

5. Risk Scoring and Risk Appetite

Likelihood Scale

Score	Rating	Interpretation
1	Rare	Highly unlikely; little exposure and strong safeguards.
2	Unlikely	Possible, but not expected under normal conditions.
3	Possible	Could reasonably occur during the assessment period.
4	Likely	Common threat pattern or recurring exposure makes occurrence credible.
5	Almost Certain	Frequent threat, direct exposure or major control gap creates a strong likelihood.

Impact Scale

Score	Rating	Interpretation
1	Insignificant	Minimal operational, financial or information-security impact.
2	Minor	Contained disruption or limited exposure with straightforward recovery.
3	Moderate	Material departmental disruption, moderate loss or confidential-data impact.
4	Major	Serious interruption, significant loss, major exposure or reputational impact.
5	Severe	Enterprise-wide outage, major fraud, destructive compromise or severe loss of critical services/data.

Risk Rating Bands

Score	Rating	Expected Management Response
1-4	Low	Normally managed through standard controls and monitoring.
5-9	Moderate	Business owner manages and documents controls; monitor and review.
10-15	High	Formal treatment plan and accountable owner required.
16-25	Critical	Priority treatment and senior management oversight; explicit acceptance required if retained.

For this fictional organization, Critical and High residual risks are generally above appetite. Moderate residual risks may be tolerated when ownership, evidence and monitoring are clear. Low risks are normally within tolerance. This appetite statement is an assessment assumption and would require real board or executive approval in practice.

6. Technology Environment, Business Services and Crown Jewels

Environment Snapshot

13	18	18	20
Critical Assets	High Assets	Internet-Facing Assets	Needs Improvement / Weak

Crown-Jewel Assets

Priority	Asset	Why It Matters	Primary Security Focus
1	Microsoft Entra ID	Controls authentication and privileged access to most cloud services.	MFA, conditional access, privileged access governance, logging
2	Microsoft 365 Tenant	Central platform for email, collaboration and business files.	Identity hardening, email security, sharing controls, monitoring
3	Cloud Accounting System	Supports billing, financial records and management reporting.	MFA, segregation of duties, audit logs, vendor assurance
4	Financial Records Dataset	High-integrity financial information is essential to operations and fraud prevention.	Integrity monitoring, least privilege, backup/export validation
5	Backup Repository	Primary recovery path for ransomware and infrastructure failure.	Separate credentials, immutability, restore testing, network isolation
6	Administrative Credentials / Secrets	Provides privileged access across the environment.	Vaulting, MFA, break-glass controls, rotation, audit logging
7	Kingston Internet Firewall	Primary perimeter and VPN security control for headquarters.	Firmware, MFA, configuration baseline, rule review, logging
8	Customer Master Dataset	Supports customer relationships, sales and service delivery.	Access control, DLP, export governance, retention

Critical Business Services

Service	Owner	Target RTO	Target RPO	Key Dependency
Corporate Email & Collaboration	COO	4 hours	4 hours	Microsoft 365 + Entra ID + DNS + Internet
Financial Operations	Finance Manager	4 hours	4 hours	Accounting SaaS + Finance identities + Internet
Corporate Network & Remote Access	IT Manager	4 hours	1 hour	ISP + Firewalls + Network + Identity
Cybersecurity Monitoring & Response	IT Manager	4 hours	2 hours	EDR + Email Security + Logs + IT Staff
Backup & Recovery	IT Manager	4 hours	4 hours	Backup Repository + Cloud Copy + Admin Credentials

Key Asset Governance Findings

- Microsoft 365 and Entra ID are both internet-facing and enterprise-critical; incomplete MFA and privilege review increase identity risk.
- Legacy Active Directory and file services have the weakest security posture and provide a realistic ransomware/lateral-movement path.
- Backup capability exists, but immutability and restoration performance are not fully evidenced.
- RMM/MSP capabilities are high-impact trusted paths and require stronger supplier assurance and access governance.
- Customer, HR and financial datasets exist in multiple systems, increasing access, export and retention governance complexity.

7. Threat and Vulnerability Assessment

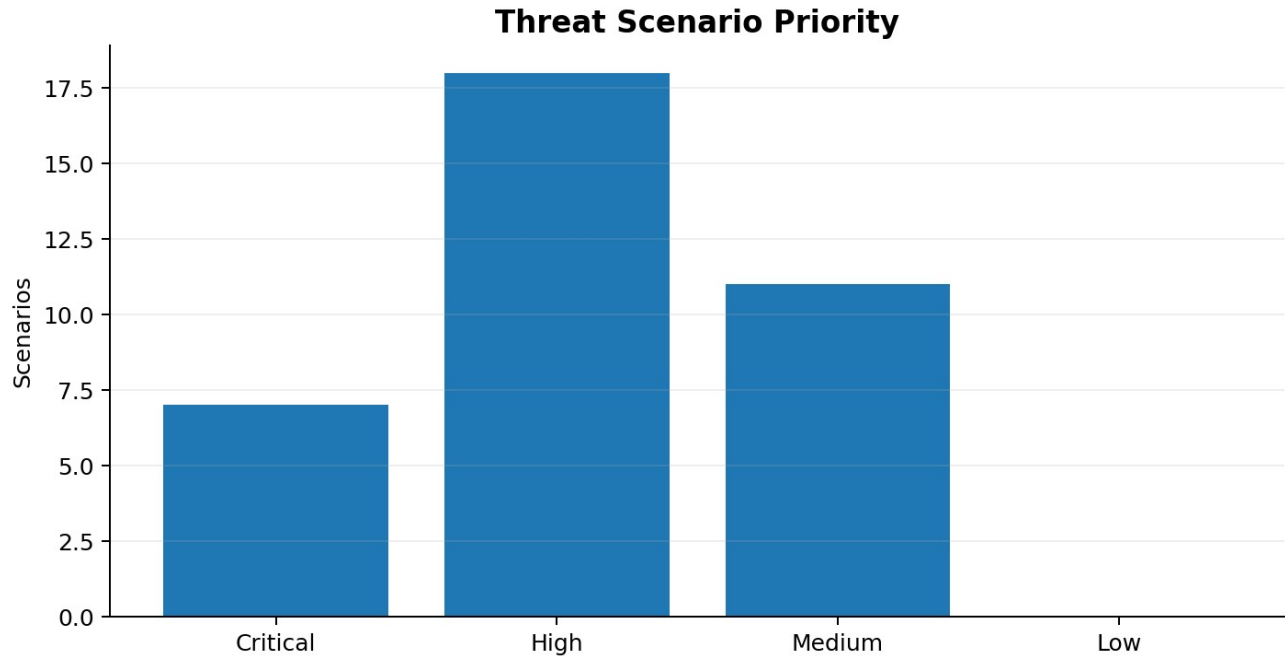


Figure 3. Threat and vulnerability scenario priority distribution.

Thirty-six adversarial and resilience scenarios were assessed. Seven were screened as Critical priority, eighteen High and eleven Medium. The matrix deliberately includes both malicious and non-adversarial events because cyber risk management must account for technology failure, supplier outage and recovery failure as well as cyberattack.

Highest-Exposure Threat Themes

Theme	Representative Exposure	Why It Matters
Identity and privileged access	Incomplete MFA, stale privilege, unmanaged legacy secrets and general-purpose admin workstations.	Credential compromise can move rapidly from a user account to enterprise administration.
Ransomware and recovery	Hybrid endpoints, legacy permissions, lateral movement and unproven immutable recovery.	Operational disruption becomes materially worse when backups cannot be trusted.
Business email compromise	Finance/executive mailboxes, payment changes and impersonation.	Combines common social engineering with direct financial impact.
Third-party / RMM	Managed remote access, MSP technicians and critical SaaS dependencies.	Trusted tools can bypass normal perimeter assumptions and scale compromise.
Cloud data leakage	External sharing, bulk exports and duplicate sensitive-data copies.	Valid users or compromised accounts can exfiltrate data without malware.
Perimeter / VPN	Internet-facing appliances, firmware lifecycle, configuration consistency and MFA gaps.	Provides a direct remote entry path into internal resources.

8. Multi-Stage Attack Paths

The threat assessment was not limited to isolated vulnerabilities. Seven attack paths were modeled to show how weaknesses can combine across systems and controls.

Path	Entry Point	Key Steps	Target	Control Breakpoints
Phishing → M365 account → finance fraud	Finance mailbox	1) Credential phishing 2) Account takeover 3) Inbox monitoring 4) Payment-change impersonation	Financial records / Accounting	MFA coverage; anti-impersonation; payment verification; anomalous sign-in detection
Phishing → endpoint → credential theft → ransomware	Employee laptop	1) User executes payload 2) Credential theft 3) Lateral movement 4) Legacy server access 5) Backup interference 6) Encryption	Backups / Legacy file services	EDR; local-admin control; legacy hardening; network segmentation; immutable backups
VPN credential → legacy network → domain compromise	Remote access VPN	1) Stolen legacy VPN password 2) Remote entry 3) Discover AD/file services 4) Credential dumping 5) Privilege escalation	Legacy AD / Admin credentials	MFA; inactive-account review; segmentation; legacy reduction; EDR
RMM/MSP compromise → mass endpoint administration	Trusted third party	1) Vendor/admin compromise 2) RMM access 3) Script/command deployment 4) Endpoint takeover	Endpoint fleet / Admin credentials	Vendor MFA; least privilege; vendor assurance; admin logs; EDR behavioral detections
Cloud sharing/export abuse → data exfiltration	SharePoint / CRM	1) Valid account 2) Bulk export or anonymous link 3) Copy to unmanaged location	Customer master dataset	Least privilege; DLP; sharing restrictions; export alerts; access review
Firewall exploit → internal foothold → admin credential theft	Internet-facing firewall	1) Public exploit 2) Device/network foothold 3) Credential access 4) Lateral movement	Identity / Admin credentials	Firmware SLA; exposure management; MFA; network segmentation; centralized logs
Domain registrar takeover → email/web redirection	Registrar account	1) Credential compromise 2) Change DNS/MX 3) Redirect users/mail 4) Harvest credentials or disrupt service	M365 / Public website	Registrar MFA; recovery contacts; change alerts; DNS monitoring

Most Concerning Path

Phishing -> Endpoint -> Credential Theft -> Ransomware

A user executes a malicious payload, the attacker steals credentials, moves laterally into legacy services, interferes with backups and encrypts shared infrastructure. The path crosses endpoint hardening, identity, legacy isolation, monitoring, privileged access and recovery controls; this is why ransomware risk remains High even after treatment is modeled.

Control Design Implication

No single security product closes these paths. Risk reduction depends on layered controls that interrupt different stages: phishing-resistant authentication, endpoint hardening, least privilege, segmentation, centralized detection, incident containment and tested recovery. The assessment therefore prioritizes control combinations rather than isolated tool purchases.

9. Enterprise Risk Profile

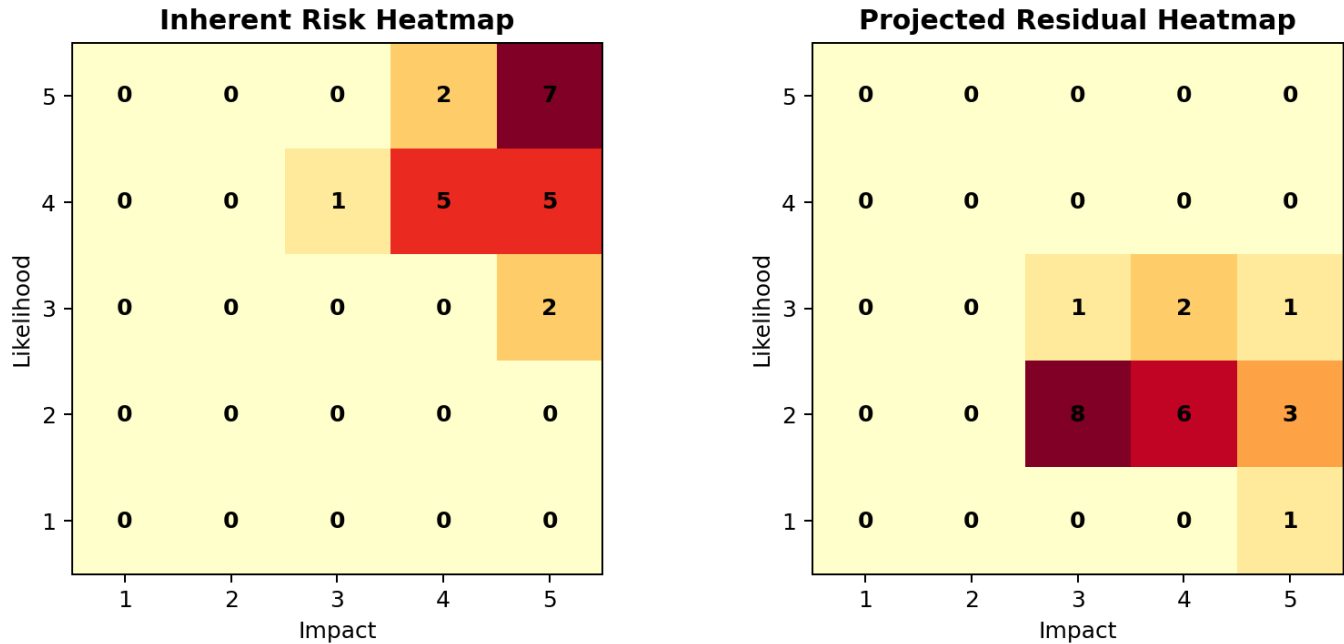


Figure 4. 5 x 5 inherent and projected residual risk heatmaps.

The inherent profile is concentrated in the upper-right portion of the matrix: nineteen risks are Critical and three High. After planned treatment, the modeled distribution shifts to six High and sixteen Moderate, with no Critical ratings. The change is meaningful, but it is a forecast contingent on control implementation and evidence.

19

Inherent Critical

3

Inherent High

6

Projected High

16

Projected Moderate

Risk Concentration

- Identity, privilege and network perimeter risks combine high likelihood with severe enterprise impact.
- Ransomware, backup and legacy infrastructure risks remain High in the projected state because business impact stays severe even when likelihood is reduced.
- Third-party and SaaS risks cannot be eliminated internally; supplier governance, contracts, resilience and exit planning reduce or transfer portions of exposure.
- Several data-protection risks move to Moderate when sharing, export, access and monitoring controls are implemented.

10. Top Enterprise Risks - Part 1

The first five priorities are concentrated in identity, privileged access, ransomware, recovery and legacy infrastructure. The table below summarizes the risk decision without replacing the detailed risk register.

Risk	Owner	Inherent	Projected Residual	Key Weakness	Treatment Focus
R-03 - Cloud Account Compromise from Incomplete MFA	IT Manager	25 Critical	8 Moderate	MFA coverage is incomplete; some VPN/cloud accounts remain exempt and inactive-account review is inconsistent.	Enforce MFA for all users and VPN accounts; disable legacy authentication; review dormant accounts monthly; implement risk-based conditional access and impossible-travel/anomalous-login alerts.
R-04 - Privileged Identity / Administrator Takeover	IT Manager	25 Critical	10 High	Privileged assignments are not regularly recertified; admin work occurs from general-purpose workstations; some secrets remain outside the central vault.	Implement quarterly privileged-role review; deploy privileged access workstations or hardened admin profiles; centralize all admin secrets in vault; rotate legacy secrets; use separate admin accounts; enable privileged activity alerts.
R-05 - Ransomware / Enterprise File Encryption	IT Manager	25 Critical	15 High	Mixed endpoint patch cadence, local-admin exceptions, legacy technical debt, inherited file permissions and limited monitoring increase lateral-movement potential.	Standardize patch SLA; remove unnecessary local admin; segment legacy servers; tighten file permissions; expand EDR coverage/tuning; block common ransomware execution paths; test ransomware containment playbook.
R-06 - Backup Compromise / Recovery Failure	IT Manager	25 Critical	10 High	Immutability/offline protection is unconfirmed, restore testing is ad hoc and backup credentials remain high-value.	Enable immutable or logically isolated backups; use separate identity/MFA for backup admins; perform quarterly restore tests; document RTO/RPO evidence; monitor deletion/configuration changes; maintain offline recovery documentation.
R-07 - Legacy Infrastructure Exploitation	IT Manager	25 Critical	12 High	Technical debt, broad permissions and limited monitoring remain in the legacy environment.	Develop decommission/migration plan; isolate legacy VLAN; patch or apply compensating hardening; remove obsolete protocols/accounts; recertify file permissions; forward logs to central monitoring.

11. Top Enterprise Risks - Part 2

The next five priorities include perimeter/VPN exposure, business email compromise, trusted remote-management risk, critical SaaS dependency and financial-record integrity.

Risk	Owner	Inherent	Projected Residual	Key Weakness	Treatment Focus
R-13 - Firewall / VPN Exploitation	IT Manager	25 Critical	8 Moderate	Firmware lifecycle, rule review and baseline management are inconsistent; some VPN accounts lack MFA.	Establish monthly firmware/vulnerability review; require admin MFA; enforce VPN MFA for all accounts; quarterly firewall-rule recertification; standardized configuration baseline; centralize firewall/VPN logs.
R-01 - Business Email Compromise / Payment Fraud	Finance Manager	25 Critical	10 High	Payment-change verification is informal; finance impersonation protections and segregation-of-duties assurance are incomplete.	Implement dual verification for banking/vendor changes; enable advanced anti-impersonation controls; strengthen conditional access; configure anomalous-payment/change alerts; review accounting role separation.
R-14 - RMM / Managed IT Supply-Chain Compromise	IT Manager	20 Critical	8 Moderate	RMM has broad control; vendor assurance, role permissions, contractual obligations and offboarding evidence need strengthening.	Require vendor MFA for every technician; named accounts only; quarterly third-party access review; restrict RMM roles; review vendor security assurance; alert on mass remote actions; define immediate vendor offboarding.
R-15 - Critical SaaS Vendor Breach	COO / Procurement	20 Critical	12 High	Vendor assurance, recovery evidence and ongoing supplier-risk review are inconsistent.	Implement annual critical-vendor review; obtain assurance reports; define breach notification and cooperation; verify backup/BCP; document exit/export plan; assess cyber-insurance/contract liability.
R-12 - Accounting System Integrity Compromise	Finance Manager	20 Critical	8 Moderate	Vendor logging has not been formally reviewed and change verification/segregation controls need stronger assurance.	Enforce role segregation; review privileged/accounting roles quarterly; alert on bank/vendor master changes; retain independent transaction audit trail; review vendor logging and assurance.

12. NIST CSF 2.0 Current vs. Target Profile

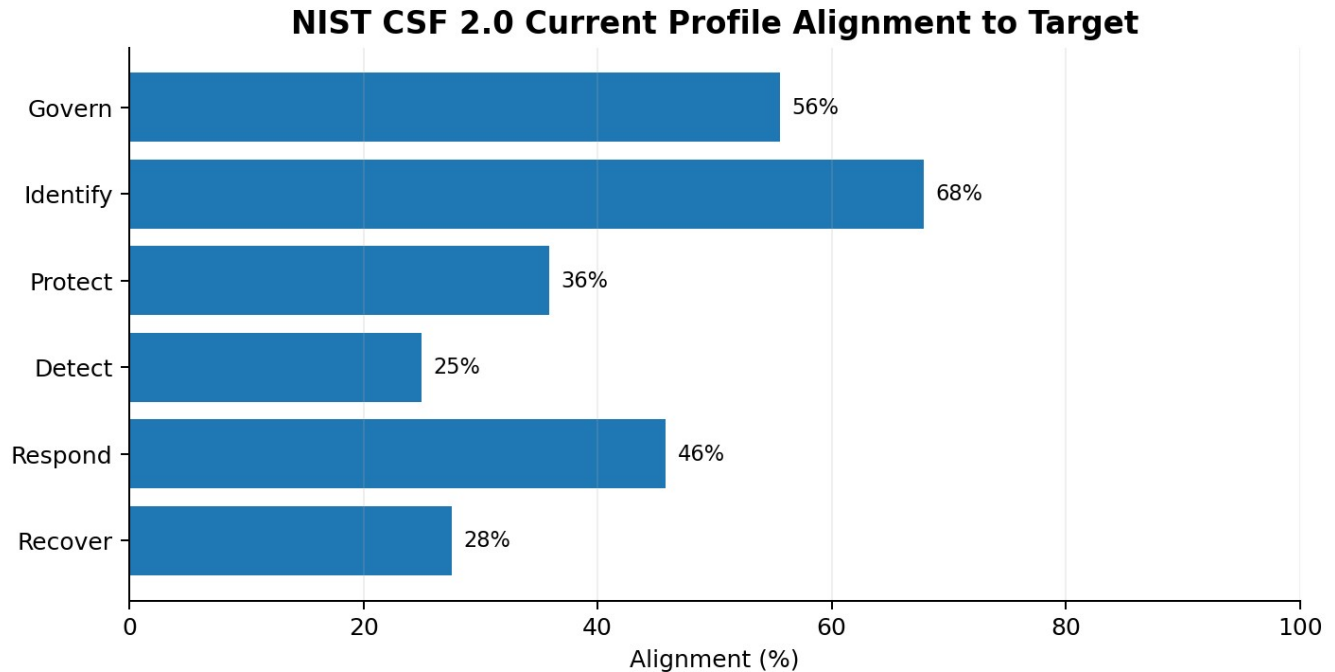


Figure 5. Function-level alignment of the simulated Current Profile to the risk-informed Target Profile.

The assessment maps the environment to all 22 NIST CSF 2.0 Categories across Govern, Identify, Protect, Detect, Respond and Recover. The internal 0-4 implementation scale is a portfolio scoring convention used to compare Current and Target Profiles; it is not a NIST Implementation Tier, certification score or maturity rating.

Function	Alignment	Average Gap	Interpretation
Govern	56%	1.7	Risk assessment exists, but formal policy, oversight and supplier governance are still developing.
Identify	68%	1.3	Asset/risk identification is relatively mature; repeatable reassessment and improvement processes need strengthening.
Protect	36%	2.4	Largest control gaps are in access, data protection, platform hardening and infrastructure resilience.
Detect	25%	3.0	Monitoring and analysis are among the weakest areas due to fragmented telemetry and informal alert processes.
Respond	46%	2.0	Operational response capability exists, but repeatable incident plans, analysis and communication require formalization.
Recover	28%	2.5	Backups exist, but tested recovery execution and recovery communications are not yet mature.

Key Profile Finding

Identify is the strongest function at approximately 68% of the Target Profile. Detect (25%) and Recover (28%) are weakest, followed by Protect (36%). This pattern matches the risk register: the organization can identify its assets and risks more effectively than it can consistently prevent, detect and recover from high-impact events.

13. Priority NIST CSF 2.0 Control Gaps

Category	Current -> Target	Linked Risks	Primary Gap	Priority Improvement
GV.RR Roles, Responsibilities & Authorities	2 -> 4	R-04; R-14; R-20	Privileged administration and supplier oversight remain concentrated; RACI and escalation authorities are informal.	Create cybersecurity RACI, privileged-access responsibilities and incident decision authorities.
GV.OV Oversight	2 -> 4	R-01 through R-22	No recurring management review, KRIs/KPIs, exception governance or evidence of remediation closure reviews.	Establish quarterly cyber-risk steering review with metrics, overdue-action tracking and risk acceptance decisions.
GV.SC Cybersecurity Supply Chain Risk Management	1 -> 4	R-14; R-15; R-22	Supplier assurance, minimum contract clauses, privileged third-party access review and exit planning are inconsistent.	Implement tiered vendor risk management, annual critical-vendor assurance, minimum security clauses and quarterly privileged-access review.
ID.IM Improvement	2 -> 4	R-06; R-18; R-20; R-21	Lessons learned, tabletop exercises, post-incident reviews and formal control-testing cycle are immature.	Create annual control-assurance calendar covering restores, IR tabletop, access review, firewall review and supplier evidence.
PR.AA Identity Management, Authentication & Access Control	1 -> 4	R-02; R-03; R-04; R-10; R-11; R-12; R-13; R-14; R-17; R-19; R-20	MFA coverage incomplete; stale privileges, legacy accounts, broad exports and general-purpose admin access remain.	Universal MFA, conditional access, quarterly access recertification, separate admin accounts and hardened privileged access.
PR.DS Data Security	1 -> 4	R-08; R-09; R-10; R-11; R-12; R-19	External sharing, bulk exports, endpoint encryption validation, DLP, data retention and sensitive-data handling are inconsistent.	Validate encryption; deploy DLP/sensitivity labels; restrict exports/sharing; define secure data-handling and retention standards.
PR.PS Platform Security	2 -> 4	R-05; R-07; R-08; R-13; R-16; R-20	Mixed patch cadence, legacy systems, local-admin exceptions, firewall baselines and CMS patch ownership remain weak.	Establish patch/vulnerability SLA, secure configuration baselines, local-admin restrictions and legacy isolation/migration.
PR.IR Technology Infrastructure Resilience	1 -> 4	R-05; R-06; R-15; R-21; R-22	Backup immutability, restore evidence, virtualization redundancy and primary-site connectivity resilience are incomplete.	Implement immutable recovery, quarterly restore tests, alternate connectivity and legacy-host resilience/migration plan.
DE.CM Continuous Monitoring	1 -> 4	R-02; R-03; R-04; R-05; R-10; R-13; R-14; R-18; R-19	Coverage is fragmented; critical SaaS and legacy logs are missing and alert ownership is informal.	Centralize priority telemetry; define alert ownership, retention and monitoring use cases; monitor privileged/vendor/data-export activity.
DE.AE Adverse Event Analysis	1 -> 4	R-02; R-04; R-05; R-14; R-18	No formal triage matrix, correlation rules, baselines, escalation thresholds or documented investigation workflow.	Define severity/triage criteria, correlation use cases, investigation checklist and escalation SLA.
RS.MA Incident Management	2 -> 4	R-01; R-02; R-05; R-06; R-13; R-14; R-18	Formal incident response plan, incident roles, severity levels, evidence handling and exercise cadence are incomplete.	Approve incident response plan, severity model, incident commander role and annual tabletop exercise.
RS.AN Incident Analysis	1 -> 4	R-02; R-04; R-05; R-14; R-18	Fragmented logs and lack of formal analysis playbooks limit root-cause and scope determination.	Create BEC, ransomware, cloud-account and vendor-access investigation playbooks; preserve evidence sources.
RS.MI Incident Mitigation	2 -> 4	R-03; R-04; R-05; R-13; R-14	Containment actions are not documented as repeatable playbooks and vendor/RMM emergency isolation procedures are unclear.	Document tested containment playbooks: compromised account, ransomware, VPN/firewall, RMM/vendor and cloud data exposure.
RC.RP Incident Recovery Plan Execution	1 -> 4	R-05; R-06; R-15; R-21; R-22	Restore testing is ad hoc; recovery sequencing, validation criteria and alternate procedures are incomplete.	Document recovery runbooks by critical service; test restores quarterly; validate RTO/RPO; track recovery dependencies.
RC.CO Incident Recovery Communication	1 -> 3	R-15; R-21; R-22	No recovery-status communication plan, stakeholder update templates or service-restoration notification process.	Define recovery communication roles, cadence, service-status templates and vendor/customer messaging process.

Profile Interpretation

- Govern: risk assessment is established, but supplier governance, policy, oversight and role clarity need formalization.

- Identify: asset and risk inventories are comparatively strong; recurring reassessment, threat input and control assurance should be operationalized.
- Protect: identity, data, platform and infrastructure resilience contain major gaps and drive several top risks.
- Detect: fragmented telemetry and informal event analysis are the largest capability gap.
- Respond: operational knowledge exists, but repeatable plans, playbooks, severity, analysis and communication are incomplete.
- Recover: backups exist, but restoration performance, service sequencing and stakeholder recovery communication are not yet fully evidenced.

14. Risk Treatment Strategy

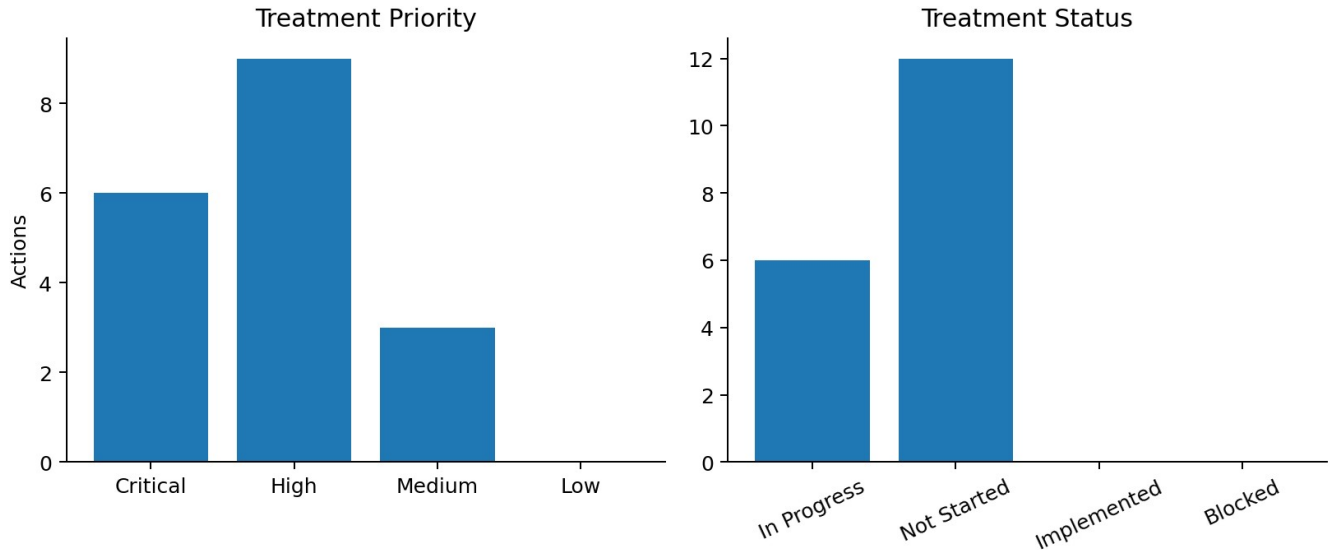
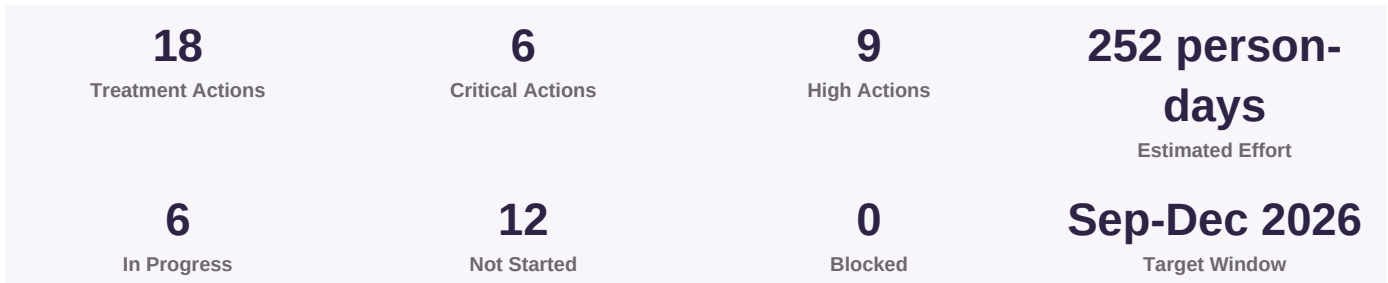


Figure 6. Treatment-plan priority and status at the assessment date.



The treatment program uses 18 actions organized into workstreams. Six actions are marked In Progress at the assessment date. Effort estimates are planning assumptions, not vendor quotations. Budget tiers are qualitative so the roadmap can distinguish staff/configuration work from activities likely to require licensing, infrastructure or supplier expenditure.

Treatment Design Principles

- Prioritize controls that interrupt multiple attack paths and protect crown-jewel assets.
- Separate accountable ownership from day-to-day implementation responsibility.
- Define observable success criteria and evidence for every action.
- Do not reduce residual risk because a project is "complete"; validate operating effectiveness first.
- Use dependencies and milestones to make implementation constraints visible to management.
- Reassess risk after control evidence is available and after major changes or incidents.

15. 30 / 60 / 90-Day Remediation Roadmap

Phase	Objective	Priority Actions	Risk Outcome	Success Gate
0–30 Days	Close the easiest high-impact entry paths and establish management control.	TP-01 Universal MFA; begin TP-02 payment verification; begin TP-04 immutable recovery; begin TP-05 perimeter hardening; start TP-13 risk governance.	Reduce immediate credential, BEC, VPN and ransomware-recovery exposure.	Universal MFA substantially complete; finance callback procedure operating; backup/perimeter implementation underway; risk appetite draft ready.
31–60 Days	Harden privileged access, financial integrity, perimeter controls and recovery.	Complete TP-02; TP-03 privileged governance; TP-04 recovery; TP-05 perimeter; TP-13 risk appetite/oversight.	Move highest inherent Critical risks toward High/Moderate residual positions.	Privileged inventory/review active; tested restore evidence; firewall/VPN baseline complete; quarterly risk governance approved.
61–90 Days	Standardize endpoint/platform hygiene and create repeatable operational governance.	TP-06 patch/baseline; TP-15 risk/asset refresh; TP-17 endpoint encryption/compliance; continue legacy reduction.	Reduce ransomware, endpoint and stale-risk exposure; improve operating consistency.	Patch compliance ≥95%; endpoint encryption ≥98%; quarterly asset review established; threat/vulnerability cadence operating.
90+ Days	Build sustainable monitoring, incident readiness, data protection, supplier governance and resilience.	TP-07 legacy migration; TP-08 monitoring; TP-09 IR; TP-10 vendors; TP-11 data controls; TP-12 awareness; TP-14 policy; TP-16 resilience; TP-18 web/domain.	Improve Detect/Respond/Recover and reduce structural supplier/data/legacy gaps.	Priority telemetry centralized; IR tabletop complete; vendor program operational; DLP/sharing controls active; core policy suite approved.

Roadmap Logic

The first 30 days focus on authentication, payment fraud, recovery, perimeter hardening and governance because these controls either close direct entry paths or materially reduce the consequences of a successful attack. Days 31-60 complete privileged access and recovery foundations. Days 61-90 improve endpoint/platform operating discipline. The 90+ day phase develops sustainable monitoring, incident readiness, supplier governance, data protection, policies, training and infrastructure resilience.

Year-End Reassessment

At the end of 2026, management should perform a formal risk re-baseline. Each action should be tested against its success criteria, evidence should be attached to the risk record, NIST Current Profile scores should be updated, and projected residual risks should be replaced with evidence-based current residual ratings.

16. Remediation Workstreams

Identity & Privileged Access

2 action(s), approximately 26 person-days of planned effort. Primary risks: R-03; R-04; R-13; R-20

Action	Priority	Owner	Target	Success Criterion
TP-01	Critical	IT Manager	15 Sep 2026	100% interactive workforce and VPN accounts protected by MFA; legacy authentication disabled; exceptions documented and approved.
TP-03	Critical	IT Manager	31 Oct 2026	All privileged accounts inventoried; zero routine administration from standard identities; all legacy secrets vaulted; quarterly review completed.

Financial Fraud Prevention

1 action(s), approximately 6 person-days of planned effort. Primary risks: R-01; R-12

Action	Priority	Owner	Target	Success Criterion
TP-02	Critical	Finance Manager	30 Sep 2026	100% vendor-bank changes independently verified; anti-impersonation policy tested for finance/executives; audit sample shows dual approval.

Resilience & Ransomware

2 action(s), approximately 28 person-days of planned effort. Primary risks: R-05; R-06; R-21; R-22

Action	Priority	Owner	Target	Success Criterion
TP-04	Critical	IT Manager	31 Oct 2026	Immutable retention enabled; separate MFA-protected backup identity used; quarterly restore test succeeds within target RTO/RPO.
TP-16	Medium	COO / IT Manager	31 Dec 2026	Secondary connectivity solution approved/tested; host rebuild procedure validated; recovery communication template approved.

Network & Platform Security

2 action(s), approximately 30 person-days of planned effort. Primary risks: R-05; R-07; R-08; R-13

Action	Priority	Owner	Target	Success Criterion
TP-05	Critical	IT Manager	15 Oct 2026	Current supported firmware; 100% VPN/admin MFA; signed rule review; configuration backup; logs visible in central monitoring.
TP-06	High	IT Manager	30 Nov 2026	≥95% critical/high patch compliance within SLA; local-admin exceptions approved; baseline deviations tracked and remediated.

Legacy Technology Reduction

1 action(s), approximately 30 person-days of planned effort. Primary risks: R-05; R-07; R-21

Action	Priority	Owner	Target	Success Criterion
TP-07	High	IT Manager	15 Dec 2026	Legacy VLAN isolation validated; obsolete accounts/protocols removed; migration roadmap approved; priority data moved to supported platforms.

Detection & Response

2 action(s), approximately 38 person-days of planned effort. Primary risks: R-01; R-02; R-04; R-05; R-13; R-14; R-18

Action	Priority	Owner	Target	Success Criterion
TP-08	High	IT Manager	15 Dec 2026	Priority log sources onboarded; alert severity matrix approved; defined detections tested; critical alerts assigned and handled within SLA.
TP-09	High	IT Manager	15 Dec 2026	IR plan approved; severity model defined; five playbooks completed; tabletop exercise held; lessons assigned to owners.

Third-Party Risk

1 action(s), approximately 18 person-days of planned effort. Primary risks: R-14; R-15; R-22

Action	Priority	Owner	Target	Success Criterion
TP-10	High	COO / Procurement	15 Dec 2026	Critical vendor register approved; assurance reviewed annually; minimum security clauses defined; privileged vendor access reviewed quarterly.

Data Protection & Human Factors

2 action(s), approximately 28 person-days of planned effort. Primary risks: R-01; R-02; R-09; R-10; R-11; R-19

Action	Priority	Owner	Target	Success Criterion
TP-11	High	COO	15 Dec 2026	Anonymous links disabled by default; DLP rules active; bulk exports restricted/alerted; quarterly access/share review completed.
TP-12	High	HR Manager	15 Dec 2026	≥95% annual training completion; quarterly phishing simulations; targeted modules completed; repeat-click rate trends downward.

Governance & Oversight

3 action(s), approximately 30 person-days of planned effort. Primary risks: R-01 through R-22; R-03; R-05; R-07; R-08; R-09; R-13; R-16; R-20

Action	Priority	Owner	Target	Success Criterion
TP-13	Critical	COO / Executive Team	31 Oct 2026	Risk appetite statement approved; quarterly cyber-risk meeting scheduled; decisions/minutes maintained; overdue actions escalated.
TP-14	High	COO / IT Manager	15 Dec 2026	Core policy suite approved and communicated; named owners/review dates; cybersecurity RACI approved.
TP-15	Medium	IT Manager	30 Nov 2026	Monthly vulnerability/threat review completed; risk register updated after major incidents/changes; asset inventory reconciled quarterly.

Endpoint & Data Security

1 action(s), approximately 10 person-days of planned effort. Primary risks: R-08; R-19

Action	Priority	Owner	Target	Success Criterion
TP-17	High	IT Manager	30 Nov 2026	≥98% managed laptops encrypted; non-compliant devices blocked from sensitive cloud access; remote-wipe test completed.

Public & Domain Security

1 action(s), approximately 8 person-days of planned effort. Primary risks: R-16; R-17

Action	Priority	Owner	Target	Success Criterion
TP-18	Medium	IT Manager / Marketing Manager	15 Dec 2026	Supported CMS/plugins; MFA on registrar/CMS admins; DNS/domain alerts enabled; recovery contacts tested; restoration procedure documented.

17. Governance, Metrics and Assurance

Key Risk / Performance Indicators

Metric	Baseline	Target	Owner	Frequency	Evidence
Workforce/VPN MFA coverage	Incomplete / exceptions exist	100%	IT Manager	Monthly	Identity/VPN configuration export
Privileged accounts recertified	Ad hoc	100% quarterly	IT Manager	Quarterly	Privileged access review
Critical/high patch compliance within SLA	Mixed cadence	≥95%	IT Support Lead	Monthly	Patch compliance dashboard
Managed laptop encryption coverage	Requires validation	≥98%	IT Support Lead	Monthly	Endpoint compliance dashboard
Quarterly backup restore success	Ad hoc testing	100% planned tests succeed	Systems Administrator	Quarterly	Restore test report
Priority security log-source coverage	Fragmented	≥90% of defined priority sources	IT Security Analyst	Monthly	Logging coverage matrix
Critical alert ownership within SLA	Informal	≥95%	IT Security Analyst	Monthly	Incident/SIEM ticket report
Critical vendor annual assurance coverage	Inconsistent	100%	Procurement	Annual	Vendor assurance register
Anonymous external sharing enabled	Requires review	Disabled by default	IT Security Analyst	Quarterly	M365 sharing report
Security awareness completion	Not formally measured	≥95% annually	HR Manager	Quarterly	Training report
Phishing simulation repeat-click trend	No baseline	Downward trend / targeted remediation	HR / IT Security	Quarterly	Phishing simulation report
Open Critical/High treatment actions overdue	0 baseline defined	0 overdue without approved exception	COO / IT Manager	Monthly	Treatment-plan dashboard

Evidence-Based Assurance

The assessment distinguishes implementation activity from assurance. Examples of required evidence include MFA coverage exports, privileged-access reviews, patch and encryption compliance reports, backup restoration results, security logging coverage, vendor assurance packs, DLP/external-sharing reviews, incident-response exercise results and approved policy records.

A strong governance cycle should therefore connect: risk owner -> treatment action -> control owner -> evidence -> control test -> residual risk decision. This traceability prevents a project-status dashboard from being mistaken for proof that risk has actually fallen.

18. Management Recommendations

1. Complete identity hardening first

Make universal MFA, legacy-authentication removal and privileged-access governance non-negotiable. Identity is the most connected control domain in the assessment.

2. Treat backup testing as a control test, not an IT maintenance task

At least quarterly, restore representative systems/data and record timing, integrity checks, dependencies and lessons learned.

3. Create a small set of repeatable governance forums

Use one quarterly cyber-risk review for risk appetite, overdue treatment, supplier exposure, exceptions, key metrics and acceptance decisions.

4. Reduce the legacy attack surface

Segment legacy systems immediately and execute a funded migration/decommission plan rather than relying indefinitely on compensating controls.

5. Improve monitoring with defined use cases

Prioritize high-value detections for risky sign-ins, privilege changes, mass data export, RMM activity, VPN anomalies, backup changes and ransomware behaviors.

6. Formalize third-party risk around critical access and data

Tier suppliers by business impact and access. Require named accounts, MFA, assurance evidence, breach cooperation, continuity, data exit and access termination.

7. Build incident-response muscle through exercises

Run at least one cross-functional ransomware/BEC tabletop before year-end and feed lessons into control, contact and recovery improvements.

8. Reassess residual risk only after evidence

Use the target residual scores in this report as planning forecasts until control tests show that the intended safeguards are working.

19. Conclusion

IslandLink Business Services Ltd. has a recognizable cybersecurity foundation: cloud identity, endpoint protection, backups, managed network controls, business application permissions and some audit logging are already present in the simulated environment. The assessment nevertheless identifies a significant gap between these point controls and a consistently governed enterprise cybersecurity program.

The most important finding is not that the company lacks security technology; it is that identity, privilege, legacy systems, supplier access, monitoring, recovery and governance are not yet controlled with sufficient consistency and evidence. These weaknesses combine into realistic attack paths that can convert a common phishing or credential event into a high-impact enterprise incident.

The proposed remediation program is designed to interrupt those attack paths in a risk-prioritized order. If the controls are implemented and validated, the projected enterprise risk profile improves from nineteen Critical inherent risks to six High and sixteen Moderate risks, with no Critical target-state ratings. NIST CSF 2.0 alignment would also improve materially as the organization strengthens Protect, Detect, Respond and Recover capabilities.

Final Assessment

ELEVATED CURRENT CYBER RISK - PRIORITY REMEDIATION REQUIRED. The target state is achievable, but management should not treat projected residual risk as realized until evidence validates control effectiveness and formal risk owners approve the resulting risk position.

Appendix A - Asset Inventory Summary

The full asset workbook remains the authoritative detailed inventory. The table below summarizes the 35 assessed assets and the primary concern that informed later threat/risk analysis.

ID	Asset	Criticality	Exposure	Posture	Key Concern
AST-001	Microsoft 365 Tenant	Critical	Yes	Needs Improvement	User MFA coverage is incomplete; privileged roles require periodic review.
AST-002	Microsoft Entra ID	Critical	Yes	Needs Improvement	Legacy authentication and stale privileged assignments require review.
AST-003	Executive Mailboxes	High	Yes	Adequate	High-value phishing/BEC target; additional anti-phishing controls needed.
AST-004	Finance Mailboxes	High	Yes	Adequate	High BEC exposure; payment-change verification process is informal.
AST-005	Cloud Accounting System	Critical	Yes	Adequate	Vendor logging and recovery evidence not formally reviewed.
AST-006	CRM Platform	High	Yes	Needs Improvement	Local accounts and broad export permissions create data-leakage risk.
AST-007	HR Information System	High	Yes	Adequate	Sensitive data; user access reviews are not formally documented.
AST-008	SharePoint / OneDrive	High	Yes	Needs Improvement	Oversharing and anonymous/external sharing settings require review.
AST-009	Windows Employee Laptops	High	Indirect	Needs Improvement	Mixed patch cadence; local admin exceptions; encryption coverage requires validation.
AST-010	Executive Laptops	High	Indirect	Adequate	High-value target; should have stricter device and phishing controls.
AST-011	Finance Workstations	High	Indirect	Adequate	USB/removable-media and macro controls are not formally governed.
AST-012	IT Administrator Workstations	Critical	Indirect	Needs Improvement	Admin activities occur from general-purpose workstations; PAW model not implemented.
AST-013	Primary Internet Firewall — Kingston	Critical	Yes	Needs Improvement	Firmware lifecycle and rule-review process need formalization.
AST-014	Branch Firewall — Montego Bay	High	Yes	Needs Improvement	Older firmware and inconsistent configuration baseline.
AST-015	Core Network Switches	High	No	Adequate	Configuration backups exist but change-control documentation is limited.
AST-016	Corporate Wi-Fi	Medium	Indirect	Needs Improvement	Legacy shared PSK remains for some devices; guest separation should be validated.
AST-017	Remote Access VPN	Critical	Yes	Needs Improvement	Some legacy accounts are exempt from MFA; inactive accounts need review.
AST-018	Active Directory — Legacy File/Print Domain	High	No	Weak	Legacy domain remains operational with technical debt and limited monitoring.
AST-019	Legacy File Server	High	No	Weak	Broad inherited permissions and old files create ransomware/data-exposure risk.
AST-020	Virtualization Host	Critical	No	Adequate	Single-host concentration creates resilience risk.
AST-021	Backup Repository	Critical	Indirect	Needs Improvement	Immutability/offline protection not confirmed; restore tests are ad hoc.
AST-022	Remote Monitoring & Management Tool	Critical	Yes	Needs Improvement	High-impact supply-chain tool; vendor assurance and role permissions need review.

ID	Asset	Criticality	Exposure	Posture	Key Concern
AST-023	Endpoint Protection Platform	High	Yes	Adequate	Alert ownership is informal; tuning and escalation procedures need definition.
AST-024	Public Website	Medium	Yes	Needs Improvement	Plugin/CMS patching responsibility and web-form protection need clearer ownership.
AST-025	DNS / Domain Registrar	Critical	Yes	Adequate	Domain takeover would have enterprise-wide impact; recovery contacts need validation.
AST-026	Primary ISP — Kingston	Medium	Vendor Managed	Adequate	Single primary circuit; failover capacity is limited.
AST-027	Branch ISP — Montego Bay	Medium	Vendor Managed	Adequate	Failover exists but has reduced bandwidth.
AST-028	Customer Master Dataset	High	Indirect	Needs Improvement	Duplicate copies exist across systems and exports; ownership and retention are inconsistent.
AST-029	Employee HR Dataset	High	Indirect	Adequate	Highly sensitive; access review and secure export process need documentation.
AST-030	Financial Records Dataset	Critical	Indirect	Adequate	Integrity is critical; change/audit logging should be reviewed.
AST-031	Administrative Credentials / Secrets	Critical	Indirect	Needs Improvement	Some legacy credentials remain outside the central vault.
AST-032	Company Password Manager	Critical	Yes	Adequate	Emergency access and offboarding procedures require testing.
AST-033	Email Security Gateway / Anti-Phishing	High	Yes	Needs Improvement	Advanced impersonation policies are not consistently configured for finance/executives.
AST-034	Security Logging Repository	High	Yes	Needs Improvement	Coverage is incomplete; critical SaaS and legacy server logs are not fully integrated.
AST-035	Third-Party Managed IT Provider	High	Vendor Managed	Needs Improvement	Contractual security obligations, access review and offboarding evidence need strengthening.

Appendix B - Enterprise Risk Register Summary

ID	Risk	Owner	Inherent	Projected Residual	Treatment	Appetite
R-01	Business Email Compromise / Payment Fraud	Finance Manager	25 Critical	10 High	Mitigate	Above Appetite
R-02	Executive Account Compromise	CEO / IT Manager	20 Critical	8 Moderate	Mitigate	Above Appetite
R-03	Cloud Account Compromise from Incomplete MFA	IT Manager	25 Critical	8 Moderate	Mitigate	Above Appetite
R-04	Privileged Identity / Administrator Takeover	IT Manager	25 Critical	10 High	Mitigate	Above Appetite
R-05	Ransomware / Enterprise File Encryption	IT Manager	25 Critical	15 High	Mitigate	Above Appetite
R-06	Backup Compromise / Recovery Failure	IT Manager	25 Critical	10 High	Mitigate	Above Appetite
R-07	Legacy Infrastructure Exploitation	IT Manager	25 Critical	12 High	Mitigate	Above Appetite
R-08	Remote Employee Endpoint Compromise	COO / IT Support Lead	16 Critical	6 Moderate	Mitigate	Near Appetite
R-09	Cloud File Sharing / Oversharing	COO	20 Critical	6 Moderate	Mitigate	Near Appetite
R-10	Customer Data Exfiltration from CRM	Sales Director	16 Critical	6 Moderate	Mitigate	Near Appetite
R-11	HR Data Unauthorized Access or Modification	HR Manager	16 Critical	6 Moderate	Mitigate	Near Appetite
R-12	Accounting System Integrity Compromise	Finance Manager	20 Critical	8 Moderate	Mitigate	Above Appetite
R-13	Firewall / VPN Exploitation	IT Manager	25 Critical	8 Moderate	Mitigate	Above Appetite
R-14	RMM / Managed IT Supply-Chain Compromise	IT Manager	20 Critical	8 Moderate	Mitigate	Above Appetite
R-15	Critical SaaS Vendor Breach	COO / Procurement	20 Critical	12 High	Transfer	Above Appetite
R-16	Public Website / CMS Compromise	Marketing Manager	12 High	6 Moderate	Mitigate	Within Tolerance with Treatment
R-17	Domain Registrar / DNS Takeover	IT Manager	20 Critical	5 Moderate	Mitigate	Near Appetite
R-18	Security Monitoring Blind Spots	IT Manager	20 Critical	9 Moderate	Mitigate	Near Appetite
R-19	Insider Data Exfiltration	COO / HR Manager	15 High	8 Moderate	Mitigate	Near Appetite
R-20	Privileged Configuration Error	IT Manager	15 High	6 Moderate	Mitigate	Within Tolerance with Treatment
R-21	Virtualization Host Single Point of Failure	IT Manager	16 Critical	6 Moderate	Mitigate	Within Tolerance with Treatment
R-22	Primary Internet Connectivity Outage	COO / IT Manager	16 Critical	6 Moderate	Transfer	Within Tolerance with Treatment

Traceability Note

Every risk in the detailed workbook also contains source threat-scenario IDs, affected asset IDs, threat/cause, vulnerability/condition, existing controls, treatment rationale, recommended actions, target dates, NIST CSF 2.0 categories, ISO/IEC 27001:2022 control references and evidence traceability.

Appendix C - NIST CSF 2.0 Category Profile

Function	Category	Current	Target	Gap	Owner	Status
Govern	GV.OC Organizational Context	3	4	1	COO / IT Manager	Not Started
Govern	GV.RM Risk Management Strategy	3	4	1	Executive Team / IT Manager	In Progress
Govern	GV.RR Roles, Responsibilities & Authorities	2	4	2	IT Manager / HR	Not Started
Govern	GV.PO Policy	2	3	1	IT Manager / HR	Not Started
Govern	GV.OV Oversight	2	4	2	COO / IT Manager	Not Started
Govern	GV.SC Cybersecurity Supply Chain Risk Management	1	4	3	Procurement / IT Manager	Not Started
Identify	ID.AM Asset Management	3	4	1	IT Manager	In Progress
Identify	ID.RA Risk Assessment	3	4	1	IT Security Analyst	In Progress
Identify	ID.IM Improvement	2	4	2	IT Manager	Not Started
Protect	PR.AA Identity Management, Authentication & Access Control	1	4	3	IT Manager	In Progress
Protect	PR.AT Awareness & Training	2	3	1	HR / IT Security	Not Started
Protect	PR.DS Data Security	1	4	3	COO / IT Security	Not Started
Protect	PR.PS Platform Security	2	4	2	IT Manager	In Progress
Protect	PR.IR Technology Infrastructure Resilience	1	4	3	IT Manager / COO	In Progress
Detect	DE.CM Continuous Monitoring	1	4	3	IT Security Analyst	Not Started
Detect	DE.AE Adverse Event Analysis	1	4	3	IT Security Analyst	Not Started
Respond	RS.MA Incident Management	2	4	2	IT Manager	Not Started
Respond	RS.AN Incident Analysis	1	4	3	IT Security Analyst	Not Started
Respond	RS.CO Incident Response Reporting & Communication	2	3	1	COO / IT Manager	Not Started
Respond	RS.MI Incident Mitigation	2	4	2	IT Security Analyst / IT Manager	Not Started
Recover	RC.RP Incident Recovery Plan Execution	1	4	3	IT Manager / Service Owners	In Progress
Recover	RC.CO Incident Recovery Communication	1	3	2	COO / Communications	Not Started

The 0-4 values above are an internal project implementation scale for Current vs. Target Profile comparison. They are not NIST Implementation Tiers and must not be represented as official NIST maturity or compliance scores.

Appendix D - Treatment Action Summary

ID	Workstream	Priority	Owner	Target	Status	Evidence	Effort
TP-01	Identity & Privileged Access	Critical	IT Manager	15 Sep 2026	In Progress	Partial	8 d
TP-02	Financial Fraud Prevention	Critical	Finance Manager	30 Sep 2026	In Progress	Partial	6 d
TP-03	Identity & Privileged Access	Critical	IT Manager	31 Oct 2026	Not Started	Planned	18 d
TP-04	Resilience & Ransomware	Critical	IT Manager	31 Oct 2026	In Progress	Partial	12 d
TP-05	Network & Platform Security	Critical	IT Manager	15 Oct 2026	In Progress	Partial	10 d
TP-06	Network & Platform Security	High	IT Manager	30 Nov 2026	Not Started	Planned	20 d
TP-07	Legacy Technology Reduction	High	IT Manager	15 Dec 2026	Not Started	Planned	30 d
TP-08	Detection & Response	High	IT Manager	15 Dec 2026	Not Started	Planned	22 d
TP-09	Detection & Response	High	IT Manager	15 Dec 2026	Not Started	Planned	16 d
TP-10	Third-Party Risk	High	COO / Procurement	15 Dec 2026	Not Started	Planned	18 d
TP-11	Data Protection & Human Factors	High	COO	15 Dec 2026	Not Started	Planned	18 d
TP-12	Data Protection & Human Factors	High	HR Manager	15 Dec 2026	Not Started	Missing	10 d
TP-13	Governance & Oversight	Critical	COO / Executive Team	31 Oct 2026	In Progress	Partial	8 d
TP-14	Governance & Oversight	High	COO / IT Manager	15 Dec 2026	Not Started	Missing	14 d
TP-15	Governance & Oversight	Medium	IT Manager	30 Nov 2026	In Progress	Partial	8 d
TP-16	Resilience & Ransomware	Medium	COO / IT Manager	31 Dec 2026	Not Started	Planned	16 d
TP-17	Endpoint & Data Security	High	IT Manager	30 Nov 2026	Not Started	Planned	10 d
TP-18	Public & Domain Security	Medium	IT Manager / Marketing Manager	15 Dec 2026	Not Started	Planned	8 d

Treatment Validation Requirement

A treatment action should be marked effective only when its success criterion and required evidence are available. Status alone is not sufficient to justify a lower residual risk rating.

Appendix E - Framework References and Disclaimer

Framework and Methodology References

[1] NIST Cybersecurity Framework (CSF) 2.0

National Institute of Standards and Technology, 2024. The CSF provides a taxonomy of high-level cybersecurity outcomes for organizations to understand, assess, prioritize and communicate cybersecurity risk.

<https://www.nist.gov/publications/nist-cybersecurity-framework-csf-20>

[2] NIST SP 800-30 Rev. 1 - Guide for Conducting Risk Assessments

Supporting guidance for threat sources, vulnerabilities, likelihood, impact and risk-assessment processes.

<https://csrc.nist.gov/pubs/sp/800/30/r1/final>

[3] NIST CSF 2.0 Quick Start Guides

Implementation resources for Organizational Profiles, enterprise risk management, supply chain risk and related CSF uses.

<https://www.nist.gov/cyberframework/quick-start-guides>

[4] NIST SP 1308 - CSF 2.0: Cybersecurity, Enterprise Risk Management, and Workforce Management Quick-Start Guide

2026 guide supporting communication of cybersecurity risk and integration of risk-informed workforce and enterprise decisions.

<https://csrc.nist.gov/pubs/sp/1308/final>

[5] ISO/IEC 27001:2022

Supporting information-security management-system and control cross-reference. No ISO certification is claimed.

<https://www.iso.org/standard/27001>

Glossary

Term	Meaning
BEC	Business Email Compromise
CSF	Cybersecurity Framework
DLP	Data Loss Prevention
EDR	Endpoint Detection and Response
ERM	Enterprise Risk Management
IAM	Identity and Access Management
MFA	Multi-Factor Authentication
MSP	Managed Service Provider
RMM	Remote Monitoring and Management
RPO	Recovery Point Objective
RTO	Recovery Time Objective
SaaS	Software as a Service

Final Disclaimer

This report is a fictional portfolio artifact. The organization, systems, security conditions, asset owners, risk scores, treatment actions and conclusions are simulated. No real company or individual is being assessed. The report should not be used as legal advice, a certification statement, an audit opinion or evidence that a real organization meets NIST, ISO or regulatory requirements.